



Secure Baselines: 4.1

The Security of an application environment should be well defined

- All instances should follow this baseline
- Firewall Settings, Patch levels, OS filter Measurements

Integrity Measurements Check for the Secure baseline

- Should be performed often

Establish a Baseline

Create a Series of baselines

- Foundational Security Policy

Often available from the Manufacturer

- Application developer

- OS manufacturer

- Appliance manufacturer

Many OS have extensive options

- Over 3000 on Windows 10

Deploy Baselines:

We have now established detailed security baselines

- How do we put these in action?

Usually managed through a centrally administered console

Automation is key

- Deployed to hundreds of thousands of devices

Maintain Baselines:

Many are best practices, and never change

Others may have ongoing updates

- New vulnerability

- New OS

Test and measure to avoid complacency

Hardening Targets: 4.1

No System is Secure with default Configs

- Need Guidelines to keep everything safe

Hardening guides are specific to software or platform

Other guides available online

Mobile Devices:

Always-Connected Mobile technologies

- Phones, tablets, etc.
- Hardening checklists are available from manufacturers

Updates are critical

- Bug fixes / Security patches

Segmentation can protect data

- Company / User data separated

Control with a MDM

- Mobile Device Manager

Workstations:

User desktops + Laptops

- Windows, macOS, Linux, etc

Constant Monitoring and Updates

- OS, applications, firmware etc...

Automate the monthly patches

- Likely on existing process

Remove any unsecure software

Network Infrastructure devices:

- Switches, routers, etc...

- You'll never see them but they're there

Purpose Built Appliances

- Embedded OS, limited OS access

Don't use defaults

Check with Manufacturer

- Security updates

- Not usually updates frequently

Cloud Infrastructure:

Secure the Cloud Management Workstations

Least Privilege for

- All Services, Network Settings, Applications, Rights + Permissions

Configure Endpoint Detection + Response (EDR)

- All devices accessing cloud should be secure

Always have backups

- Cloud to Cloud (C2C)

Servers:

Many and Varied

- Windows, Linux, etc

Updates

- OS Updates / Services Patches, Patches

User Accounts

- Minimum Password length + Complexity
- Account limitations

Network Access + Security

- Limit Network Access

Monitor + Secure

SCADA / ICS

Supervisory Control and Data Acquisition System

- Large Scale, Multi-site, Industrial Control System (ICS)

PC Manages equipment

- Power generation, refining, Manufacturing

Distributed Control Systems

Requires extensive Segmentation

Embedded Systems:

Hardware / Software built for single Purpose

Can be difficult to Secure / Upgrade

Update ASAP

Put on own Segmented Network with firewall

RTOS (Real-Time-Operating System)

An OS with deterministic Processing Schedule

- No time to wait for other Processes

- Industrial Equipment, Automobiles, Military

Isolate the System

Use Secure Archiving

IoT Devices:

Heating, Cooling, Lighting, Home Automation

Weak Defaults

Policy Updates Required

Segment these on their own VLAN

Securing Wireless and Mobile: 4.1

Site Surveys

Determine existing wireless landscape

- Sample the existing wireless spectrum

Identify existing access points

- You may not control all of them

Work around existing frequencies

Plan for ongoing site surveys

- Things will change

Heat Map Visualization

Wireless Survey Tools:

Signal Coverage

Potential Interference

Built-in tools

3rd Party Tools

Spectrum Analyzer

Mobile Device Manager (MDM)

Manage Company-owned and user owned mobile devices

BYOD - Bring your own device (user owned)

Centralized management of the mobile devices

Set Policies on apps, data, Camera, etc

- Control the remote device
- The eraser device or 'Purition'

Manage Access Control

- Force Screen locks or Pass

BYOD

Bring your own device / Technology

Employee's device needs to meet company standards

Difficult to Secure

- Both a home + work device
- How is data protected?
- What happens to the data when a device is sold / traded in

COPE

Corporate Owned, Personally Enabled

- Company buys the device
- Used as both Personal / Corporate Device

Organization keeps full control on the device

Information is Protected using Corporate Policies

CYOD - Choose Your own device

Cellular Networks:

Mobile Devices: 4G, 5G

Segmented into 'cells'

Security Concerns

- Traffic Monitoring
- Location tracking
- Worldwide access to a mobile device

WiFi

• LAN (Local Networks)

• Same concerns as other Wi-Fi devices

Data Capture

On-Path Attack

- Can cause interference

Bluetooth:

High Speed Communication over Short distances

- PAN (Personal - Area Network)

Connects our Mobile Devices

Do NOT Connect to Unknown devices

- Formal Pairing Process should be used

Wireless Security Settings: 4.1

An organizations wireless network can contain confidential information

Authenticate the users before getting access

- Who gets access to the wireless network
- Username, Password, MFA

Ensure all data is Confidential, Encrypt the data

Verify the integrity

MIC (Message Integrity Check)

The WPA2 PSK Problem

- WPA2 has a PSK brute force issue
- Some methods can derive the PSK hash without the handshake
- Circumvents four-way handshake

With hash, attackers can brute force the Pre-Shared Key (PSK)

This has become easier as technology improves

- GPU Processing Speeds
- Cloud based Password Protection

WPA3 and GCAP

- WiFi Protected Access 3 (WPA3)

GCMP block cipher mode: Stronger than (WPA2)

GCMP Security Services: GMAC (Galois Message Authentication Code)

SAE

WPA3 Changes the PSK authentication Process

- Includes mutual authentication
- Creates a shared session key without saving it across that network

Simultaneous Authentication of Equals (SAE)

- Everyone uses a different session key, even with the same PSK
- IEEE Standard - the dragonfly handshake

Wireless Authentication Methods:

Gain Access to a Wireless Network

- Mobile Users
- Temporary Users

Credentials

- Shared Passwords / Pre-Shared Key (PSK)
- Centralized Authentication (802.1X)

Configuration

- Prompts for username / Password

Wireless Security Modes:

Configure the authentication on your wireless access point / router

Open System: No authentication password is required

WPA3-Personal / WPA3-Psk

- WPA2 or WPA3 with a preshared key

- Everyone uses the same but 256-bit key

WPA3-Enterprise / WPA3-802.1X

- Authentication uses individually with an authentication server (i.e. RADIUS)

AAA Framework:

Identification: Who you claim to be

Authentication: Prove you are who you claim to be

Authorization: What permissions do you have

Accounting: Resources used: Login time, data sent and received, logout time

RADIUS:

Remote Authentication Dial-In User Service

Very common AAA Protocol, Supported on wide variety of platforms & devices, Not just for Dial in

Centralize Authentication for core:

- Routers, switches, firewalls

- Remote VPN Access

Almost available on ALL OS

IEEE 802.1X

Port Based Network Access Control (NAC)

- No access until you authenticate

Used in conjunction with an access database

- RADIUS, LDAP, TACACS+

EAP

Extensible Authentication Protocol (EAP)

- Authentication framework

Many different ways to authenticate based on RFC Standards

EAP integrates with 802.1X

- Prevents Network Access without Authentication

Supplicant - Client

Authenticator - Device Providing Access

Auth Server - Verifies Client Credentials

Application Security: 4.1

Secure Coding Concepts:

A balance between time and quality

- Programming with security in mind is often secondary

Testing, Testing, Testing

- The Security Assurance (SQA) Process

Vulnerabilities will eventually be found

- Are exploiting

Input Validation:

What is the expected input?

- Validate actual vs. expected

Document ALL input methods

Check and correct all input (normalization)

- Zipcode should only be X characters long

- Fix any data in incoming input

The fuzzers will find what you missed

Secure Cookies:

Cookies: Information stored on your computer by the browser

Used for tracking, Personalization, Session Management

- Not executable, not generally a risk BUT could be

Secure Cookies have a Secure Attribute Set

- Browser only sends over HTTPS

Sensitive information should never be stored in a cookie

Static Code Analyzers:

Static Application Security Testing (SAST)

- Helps to identify security flaws

- Buffer overflows, database injections, etc...

Not everything can be identified through analysis

- Auth Security, insecure cryptography, etc

- Don't rely on automation

Still have to look for findings

Code Signaling:

An application is deployed

- Users run application executables or scripts

So many Security Questions

- Has the application been modified in any way?

Can be digitally signed by developer

- Asymmetric Encryption

- Trusted CA signs the developer's Private Key

- For internet Apps use their own CA

Sandboxing:

Applications cannot access unrelated resources

Commonly Used during development

Used in many different environments

- Virtual machines

- Mobile devices

- Browser i.e. Firefox

Application Security Monitoring:

Real-Time information

- Application usage, Access demographics

View blocked Attacks

Audit Logs

Anomaly Detection

- Unusual file transfers

Asset Management: 4.2

Acquisition / Procurement Process:

The Purchasing Process for requesting and obtaining goods & services

Start with a request from the end user

Negotiate with Suppliers

- Terms & Conditions

Purchase, Invoice, and Payment

Assignment / Accounting:

A Central asset tracking system

- Used by different parts of the organization

Ownership:

- Associate a person with an asset
- Useful for tracking a system

Classification:

- Type of Asset
- Hardware (Capital Expenditure)
- Software (Operating Expenditure)

Monitoring / Asset tracking:

Inventory every asset

- Laptops / Desktops, Servers, Routers, Servers, Cables

Associate a support ticket with a device make & model

Enumeration: List ALL parts of an asset

CPU, memory, storage, ...

Add an asset tag:

- Barcode, RFID, Visible tracking number

Media Sanitization:

System disposal or decommissioning

- Completely remove data

- No usable information remains

Different use cases:

- Clean a hard drive for future use

- Permanently delete files

Once it's gone it's really gone

Ensure nothing's left

Physical Destruction:

Shredder / Pulverizer

- Heavy Machinery, Complete Destruction
- Drill / Hammer

Electromagnetic (degaussing)

- Destroys magnetic info

Incineration

Certificate of Destruction:

Destruction is often done by a third party

Need Confirmation data is destroyed

Data Retention:

Backup your data

- How much, and where

Regulatory Compliance:

- A certain amount of backup may be required

Operational needs

- Accidental deletion
- Disaster Recovery

Differentiate types of data

Vulnerability Scanning: 4.3

Usually minimally invasive

- Unlike a Penetration test

Port Scan: Poke around and see whats open

Identify Systems + Security Devices

Tests are from outside AND inside

Gather as much information as possible

Static Code Analyzers

Static Application Security Testing (SAST)

- Helps to identify security flaws

Many security vulnerabilities found easily

- Buffer overflows, database injections, etc.

Not everything can be identified through code

- Authentication, security, cryptography

Still have to verify each finding (false positives)

Dynamic Analysis (Fuzzing)

Sending Random Input to an application

- Fault injecting, robustness testing, system testing

Looking for something out of the ordinary

1988 Class Project at the University of Wisconsin

Fuzzing Engines & Frameworks

Many different fuzzing options

Very time and processor heavy

- Many iterations to run
- Use high-Permeability tests

Package Monitoring:

Some applications are distributed as a Package

- Especially Open Source
- Supply Chain integrity

Confirm the Package is legitimate:

- Trusted Source
- No added malware
- No embedded Vulnerability

Test in lab environment

Threat Intelligence: 4.3

Research the threats + threat actors

Data is everywhere: Hacker group profiles, leaks..

Make decisions based on this intelligence

Used by Researchers, Security Operations, Teams + others

Open-Source intelligence (OSINT)

Open Source Intelligence

- Publicly available

Internet: Discussions, Internet groups

Government Data:

- Mostly Public hearings, reports, websites, etc

Commercial Data:

Maps, financial reports, databases

Proprietary / Third-Party intelligence:

Someone else has already compiled it

- You buy it

Threat Intelligence Services:

- Threat analysis

Constant Monitoring

Information - Sharing organization:

Public Threat Intelligence

Private threat Intelligence

Cyber Threat Alliance (CTA)

- Members Share threat intelligence

- CTA Scores + Validates each submission

Dark-Web Intelligence:

Dark Web:

Overlay networks that use the internet

Need software to access

Hacking groups & services

- Tools + Techniques

- Credit Card Sales

- Accounts & Passwords

Monitor Forums & Activity

Penetration Testing: 4.3

Pentest: Simulate an attack

Similar to Vulnerability testing. Very intrusive

Often a Compliance Mandate

- Regular 3rd Party Penetration

Rules of Engagement:

An important document

- Defines Purpose, Scope, and Parameters

Type of testing + Schedule

- On-site Physical breach, internal test, external test

The rules:

- IP address ranges

- Emergency contacts

- How to handle sensitive information

- In-Scope / Out of Scope systems

Exploiting Vulnerabilities:

Try to break into the system

This can cause a DoS or loss of data

Gain Privilege: escalation using buffer overflow

May need to try many different Vulnerability types

- Password brute force
- Social Engineering
- Database injections
- Buffer overflow

The Process:

Initial Exploitation: Get inside Network

Lateral Movement: Move from system to system

Persistence: Make a backdoor, Change Passwords

The Pivot: Gain Access to systems typically unreachable

Responsible Disclosure Program:

Takes time to fix a vulnerability

- Software Changes, testing, development, etc...

Bug Bounty Programs:

- A reward for discovering issues

Bring information to developer

Analyzing Vulnerabilities: 4.3

False Positive: Vulnerability identified doesn't really exist

This is different than a low-severity vulnerability

False Negative: Vulnerability exists but was not detected (much worse)

Upgrade to the latest signatures

Work with vulnerability detection manufacturer

Prioritizing Vulnerabilities:

Not every vulnerability has the same priority

Difficult to determine

Use resources to place in hierarchical ranking

CVSS:

National Vulnerability Database

Common Vulnerability Scoring System

*Quantitative Scoring of Vulnerability 0-10

Scoring Elements Change over time

Difference per CVSS 2.0 vs CVSS 3.x

Industry Collaboration

CVE:

The Vulnerabilities can be Cross referenced online

National Vulnerability Database

Microsoft Security Bulletins

Common Vulnerabilities and Exposures (CVE)

Some Vulnerabilities cannot be definitively Verified

Vulnerability Classification

The Scanner looks for everything (Signatures)

Application Scans: Desktop, Mobile apps

Web Application Scans

Network Scans

· Misconfig. Plugins, open ports, vulnerable devices

Exposure Factor:

Represents as a Percentage: 50% EF

Less of data if the Vulnerability is exploited

Buffer overflow: 100% Exposure Factor

A Consideration When Prioritizing

Environmental Variables:

What type of environment is associated?

- Internal, Semi, Cloud, Lab?

Prioritization and Patching frequency

- Device in test lab vs. Entire fleet

All environments are different

- Number and types of users (internal, external)

- Revenue generating application

- Ease of Exploitation

Industry / Organizational Impact:

Some exploits have awful consequences

Tallahassee Memorial Healthcare

Ransomware attack → Closed for weeks

- Diverts emergency cases

Attack On Power Utilities

Risk Tolerance:

The amount of acceptable risk for an organization

- Impractical to remove ALL risks

Timing of Security Patches

Healthy Middle Ground

Vulnerability Remediation: 4.3

Patching:

The Most Common mitigation technique

- We know it exists, easy to install

Scheduled Patches

Unscheduled Patches: zero day, Urgent

Outgoing Process

Insurance:

CyberSecurity insurance Coverage

- Lost revenue, Data recovery costs
- Money lost due to Phishing

Does not cover everything

Ransomware ~~repairs~~ Cyber Insurance

Segmentation:

Limit the Scope or an exploit

Breach can only go so far

Cont Patch → Isolate with air gap

Use internal NGFWs

- Block unwanted / unnecessary traffic between VLANs

Physical Segmentation / Logical Segmentation (VLANs)

Compensating Controls:

Optimal Security Methods May be Unavailable

- Can't deploy a patch right now
- No internal firewalls

Compensate in Other Ways:

- Disable the problematic service
- Revoke access
- Limit external access
- Modify internal Security Controls and SW Firewalls

Provide Coverage until Patch

Exceptions & Exemptions:

Removing the Vulnerability is optimal but not always possible

A balancing Act: Provide Service but also protect data & system

Not all Vulnerabilities share the same severity

- May require other things: Local login, Physical Access...

An exception MAY be an option

Validation or Remediation:

Vulnerability is now Patched. Does it Stop the exploit? Did you patch All Systems?

Rescanning: Perform another scan

Audit: Check Remediated Systems to ensure Patch was done

Verify: Manually Confirm

Reporting:

Ongoing Checks are required

Difficult or impossible to manage without automation

Continuous Reporting

Errors, exceptions, and exemptions

Security Monitoring: 4.4

Attackers NEVER Sleep

Monitor all entry points

- Logins, Publicly available Services, Data Storage locations

React to security events

Status dashboards

Monitoring Competing Resources:

Systems:

Authentications - Logins from odd places

Server Monitoring - Service Activity

Applications:

Availability - Uptime + Response time

Data Transfers - increasing / decreasing

Security Notifications

Infrastructure:

Remote Access Systems: Employees, Vendors, Guests

Firewall and IPS reports: Increase or type of attack

Log Aggregation:

SIEM or SEM (Security information + Event Manager)

- Consolidate many different logs to central database
- Servers, firewalls, VPN Concentrators, SANS

Correlation between diverse systems

- View authentication and Access
- Track Application Access
- Measure + Report

Centralized Reporting

Scanning:

A Constantly Changing Landscape

Actively Check Systems + Devices

- OS types
- Driver vers
- Installed Apps
- Anomalies

Gather raw details

Reporting:

Analyze the collected data

Status information

- Number of devices up to date / in compliance

Determine Next-Best Steps

- How many systems are affected

Ad hoc Reporting

- Probe for unknown

Archiving:

Takes Company ~9 months to identify a breach

Access to data is critical

- Archive over extended period

May have a mandate

Alerting:

Real time Notification of security events

- Increase in auth-errors
- Large file-transfers

Actionable data

Notification Methods: SMS, Email, Security Console (Sec)

Alert Response + Remediation:

Quarantine:

- Foundational security restore
- Prevent it from spreading

Alert tuning:

- Prevent false positives / false negatives

An alert should be accurate

- Ongoing process

Security Tools: 3.4

Security Content Automation Process (SCAP)

- NGFWs, IPS, Vulnerability Scanners
- They all have their own way of evaluating a threat

Managed by National Institute of Standards and Technology (NIST)

Allows tools to identify and act on same criteria

- Tools can work together

Using SCAP:

SCAP Content can be shared between tools

- Focuses on Config Compliance

Used in large environments

Enables automation with different tools

Automation Types:

- Config Monitoring
- Notification + Alerting
- Remediation of Noncompliant Systems

Benchmarks:

Apply Security best Practices to everything

- OS, Cloud Providers, etc.

- Bare minimum for Security Settings

Example: Mobile Device

- Disable Screenshots, Screen Recording, Print Voice calls...

CIS - Center for Internet Security

Agent / Agentless:

Check to see if device is in compliance

Agents can locally provide more detail

- Always monitoring But must be continuous monitoring

Agentless runs without a formal install

- Penetration check, then disappears

- Went in then if not runs

- No ongoing updates needed

SIEM

Security information + event manager

- Consolidates logs

Log aggregation + long term storage

- Used agencies referring security

Data Correlation

Forensic Analysis

- Gather info after event

Anti-virus/Anti-malware:

Refers to Security: Trojans, worms, macro viruses

Malware is broad: spyware, ransomware, fileless malware

Interchangeable: Novado-5

Data Loss Prevention (DLP)

Prevents transmission of data

Constantly monitors data for sensitive transmission

Many Sources/Destination

- Endpoint Clients

- Cloud Based Systems

SNMP

Simple Network Management Protocol

A database of data (MIB) - Management Information Base

Database contains OIDs - Object Identifiers

Polls devices over UDP/161

Requests stats from device

- Server, Firewall, Workstation, Switch

Poll devices at fixed intervals

SNMP Traps:

Most SNMP operations error a poll

SNMP traps can be configured on the monitored device

Set a threshold for alarm

- If the number of CRC errors increases by 5, send a trap

- Can react ASAP

NetFlow:

Gathers traffic statistics from all network flows

NetFlow: Standard collection method

Probe + Collector:

- Probe Watches Network Communications

Usually has a separate IP address tied to collector

Vulnerability Scanners:

Minimally Invasive

Port Scan

Identify Systems in Range

Test from outside & inside network

Gather tons of information

Firewalls: 4.5

Network Based Firewall:

Filters traffic by Port Number or application

- Traditional vs. NGFWs

Encrypts Traffic (VPN Concentrator)

Most firewalls are Layer 3 devices (routers)

Open State Ingress / egress

Next-Generation Firewall:

NGFW

The OSI Application Layer (Layer 7)

May be called:

- Application Layer gateway
- Stateful multiport inspection
- Deep Packet inspection

Requires some advanced decoders

- Every Packet must be analyzed, & categorized

Ports and Protocols

Make forwarding decisions based on Protocol (TCP/UDP) and Port number

- Traditional Planets

Based on destination Protocol & Port

Web Serv: TCP/80, TCP/443

SSH Serv: TCP/22

Firewall Rules:

Logical Path: Top to bottom

Order by Precedence

Implicit Deny:

Most firewalls implicitly deny at the bottom

ACLs (Access Control List)

- Source IP/ Dest IP, time of day, etc

Allow or disallow traffic

Rule #	Remote IP	Local Port	Protocol	Action
1	All	22	TCP	Allow
2	All	80	TCP	Allow
3	All	443	TCP	Allow
				Deny

Screened Subnet:

An additional layer of security between you and mine

- Private data remains inaccessible

Hosts Services + Devices that need to be used by Internet users

IPS Rules:

Intrusion Prevention Systems (usually integrated on firewall)

Signature Based

- Look for perfect match: Allow / Block

Anomaly Based:

- Determine what's normal
- Abnormal traffic analysis

IPS rules:

Determine when occurs when unwanted traffic occurs

Thousand + Rules

Rules can be customized by group

Can take time to balance

- Security / Alert noise / False Positive

Web Filtering: 4.5

Content Filtering:

Control traffic based on data within the Content

- URL Filtering, Website category filtering

Corporate control of outbound/inbound data

Control of inappropriate content

- NSFW, Pornel Content

Protection against evil

URL Scanning:

Allow or restrict based on a Uniform Resource Location

Also called a Uniform Resource Identifier

Monitored by category: Adult, Hacking, Religion

Can have limited control

Integrates into NSFWs

Agent Based:

Install Client on the user's device

- Usually managed by central console

Users can be located anywhere

- Always on, always filtering

Offload must be distributed to all agents

- Cloud Based Updates

Proxies:

Sits between users + external traffic

Retrieve Request from users and sends / Retrieve on their behalf

Used for caching information, access control, URL filtering, Content Scanning

Applications need to know how to use Proxy (config)

Invisible to users (transparent)

Forward Proxy

Centralized internal proxy

- Protects user access to internet

Block Rules:

Based on specific URL

Category of site content: Adult, Educational, Gambling, Government-

Different Disposition

Educational: Allow

Gambling: Block

Reputation:

Filters base on perceived risk

Bad reputation is blocked

Risk: Trustworthy, Low Risk, Suspicious, High Risk

Advanced Reputation or Manual Reputation

DNS Filtering:

Before connecting, get IP address

- Perform a DNS lookup

DNS Lookup with real time threat intelligence

- Both connection and permissions

Hidden sites are not resolved

- No IP, No connection

Work for any DNS lookup

- Not just web filtering

Operating System Security: 4.5

Active Directory:

A database of everything on the Network

• Computers, User accounts, file Shares, Printers, Groups, and More

Primarily Windows Based

Manage Authentication

Centralized Access control

Commonly used by help desk

Group Policy:

Manage the Computers or Users with Group Policies

A Central Console

• Login scripts

• Network configuration

Comprehensive control

• Hundreds of controls

Security Enhanced Linux (SELinux):

Security Patches for the Linux Kernel

- Adds Mandatory Access Control

Limits Application Access:

- Least Privilege

Open Source

Secure Protocols: 4.5

Network traffic is important

Everything must be Protected

Some Protocols aren't encrypting

- All traffic sent in the clear

- Telnet, FTP, SMTP, IMAP

Verify with a Packet capture

- View everything sent over the network

Protocol Selection:

Use a Secure application Protocol

- Built in Encryption

A Secure Protocol may not be available

- Deal Breaker

Port Selection

Secure and insecure application, connections may be available

HTTP: Port 80, HTTPS Port 443

The Port number does not guarantee security

Transfer Method:

Dont rely on the application

802.11 wireless

• Open Access Point

- WPA2: All user data is encrypted

Use VPN (encrypts tunnel) until Concentrator

Email Security: 4.5

The Protocols to transfer emails have few Security Checks

Spoofing occurs all the time

Email appears to have originated from trustworthy Sender

A malicious Sender will Configure email Validation

Mail Gateway:

The Gatekeeper:

- Evaluates source of inbound email messages
- Blocks it at the Gateway before it reaches the user
- On site or cloud-based

Sender Policy Framework (SPF):

SPF Protocol: Sender configures a list of all Servers authorized to send emails from a domain

List of Authorized Mail Servers are added to DNS TXT Record

- Receiving mail Servers Perform a Platform Check to see if incoming mail came from an authorized host

Domain Keys Identified Mail (DKIM):

A Mail Server digitally signs ALL outgoing mail

- The Public key is in the DKIM text record

The Signature is Verified by Receiving Mail Servers

DMARC:

Domain-Based Message Authentication Reporting and Conformance (DMARC)

- An extension of SPF and DKIM

The domain owner decides what receiving email servers should do with emails not verifying using SPF & DKIM

- Accept all, send to spam, or reject the email

Compliance Reports are sent to the email administrator

Monitoring Data: 4.5

FIM (File Integrity Monitoring)

Some files change All the time

- Some Never change

Monitor important OS and app files

Windows - SFC (System File Checker)

Linux - Tripwire

Many host based IPS options

Data Loss Prevention:

Sensitive data blocked from sending

Stop data before attackers get it

So many solutions in different places

Data Loss Prevention (DLP) System:

On Your Computer

- Data in use

- Endpoint DLP

On Your Network

- Data in transit / moving

On Your Server

- Data in Rest

USB Blocking:

DLP on Workstation

- Allow or Deny Certain tasks

Happened to 2008-U.S. DoD

- Worm virus agent.btz

All devices had to be updated

- Local DLP agent handles USB here etc

Cloud Based DLP:

Located between users & the internet

- Watches every byte of Network traffic

Block custom defined data strings

Manage Access to URLs

Block viruses & Malware

DLP and email:

Email continues to be most critical risk vector

Check all inbound/outbound emails with email DLP

Inbound: Block keywords, quarantine

Outbound: Fake wire transfers, WIC transfers

Emailing a Spreadsheet template:

Boeing employee left 36,000 Boeing employee Personal info

Could have been Personal with R/P

Endpoint Security: 4.5

The endpoint:

Users Access

- APPS, Data

Stop the attacks

- Inbound / Outbound attacks

Many Different Platforms

Protecting is multi-faceted: Defense-in-Depth

Edge vs. Access Control:

Edge: Part where inside of network meets outside

Managed through firewall rules

Access Control: Limit users Access to data

- Username / Group / Location, data residency, authentication

Can be revoked or changed

Posture Assessment:

You can't test everyone's computer or BYOD

- Looking for any device not up to date

- Limit their access

Is it a trusted device? Running Anti-virus? Is it encrypted?

Device type doesn't matter

Health Checks / Posture Assessment:

Persistent Agent

- Permanently installed, Needs to be updated

Dissolvable Agent

- No installation required
- Runs during Posture assessment + terminates

Agentless NAC

Integrated with Active Directory

Checks are made with login by user

Cannot be scheduled

Failing your assessment:

What happens when a Posture assessment fails?

- Too dangerous to allow access

Quarantine network, notify administrators

Once Resolved, try again

Endpoint Detection and Response (EDR):

A different approach to threat protection

Detect a threat

- Signatures & Behavioral Analysis & Machine learning & more

Investigate the threat: Root Cause Analysis

Respond to the threat

- Isolates, Quarantines, Rollback
- API driven, no user or technician intervention

Extended Detection and Response (XDR):

An evolution of EDR

- Improve missed detections, false positives and long investigation times
- Attacks involve more than the endpoint

Add a network based detection

Correlate endpoint, network & cloud data

Use Behavior Analytics:

Interprets user activity to develop a baseline

Using this normal behavior, we can detect abnormal behavior

Use a set of rules, Pattern Matching, Statistical analysis

Identity and Access Management: 4.6

IAM

Applications are available anywhere

Data can be anywhere

Many different Applications

Give right Permissions to right people at the right time

Identity and Access Management (IAM)

Identity lifecycle management

- Every entity (human and nonhuman) gets a digital identity

Access Control: User gets what they need

Authentication and authorization

- Ensures that people they are who they claim to be

Identity Governance

- Track on entities presence across

- May be a regulatory requirement

Provisioning / de-Provisioning user accounts:

The user account creation process

Provisioning + De-provisioning occurs for many events

- Hiring / transfers / Promotions

Account Details

Integration to IAM process

Permission Assignments:

Each entity gets limited permissions

- Just enough to do their job

Storage files can be private to that user

No Privileged access to the operating system

Identity Proofing:

I could be anyone

- IAM should confirm who I am

Resolution: Who system thinks you are

Validation: Gathering information

Verification / Attestation

- Password / In Person meeting, etc

- Automated versions

Single Sign On (SSO):

Provide credentials one time

- Get Access to all resources for fixed period of time

LDAP (Lightweight Directory Access Protocol):

Protocol for Accessing large directories over an IP Network

X.500 Specification was written by the International Telecommunications Union (ITU)

LDAP runs on the C/SF Protocol Stack

LDAP is the Protocol used to query or Update an X.500 dir

X.500 Distinguished Names:

Most Specific attribute listing first

X.500 Information tree

- Hierarchical Structure

- Contains Objects

- Leaf Objects

Security Assertion Markup Language (SAML):

Open Standard for authenticating and authorizing

Not designed for mobile devices

OAuth:

Authorization Framework

- Determines what resources a user will have access to

Not an authentication Protocol

- OpenID Connect handles the SSO authorization

Federation:

Provide Network Access to others

- Not just employees - Partners, Suppliers, Customer

Log-on with Twitter, Facebook, LinkedIn OR email

Interoperability:

Many different ways to communicate with an authorization server

Often determined by what is at hand

- VPN Connector can talk to LDAP

A good app uses OAuth

- Need to Allow Authentication API Access

Access Controls: 4.6

Authorization

The Process of ensuring only authorized rights are exercising

Policy enforcement

The Process of determining rights

Users receive rights based on Access Control Model

Least Privilege:

Give bare minimum Privilege

Only get what's needed

Don't allow users to run with admin Privilege

Mandatory Access Control (MAC)

Operating System limits the operations based on an object

Every object gets a label

Confidential, Secret, Top Secret

Labeling of objects use Pre-defined rules

Users can't change these

Discretionary Access Control (DAC):

Used in most OS

User determines who gets access + what permissions

Very flexible access control

- Very Weak Security

Role-Based Access Control (RBAC)

Your permissions are based on your job role

Administrators provide access based on the role of the user

- Rights are granted implicitly

In windows, use groups to provide role based access control

Rule-Based Access Control:

Generic term for following rules

Access is determined through system rules

The rule is associated with an object

- System checks ACLs for that object

Rule Examples

"Lab open 9-5, denies entry at 6

Attribute Based Access Control:

Users can have complex relationships to applications and data.

- Access may be based on many different criteria

ABAC can be considered many Parameters

- A 'next-generation' authorization model

- Aware of context

Combine and evaluate multiple Parameters

- Resource information, IP address, time of day, device, action, etc. of day

Time-of-Day Restriction:

Access varies by time of day

Can be difficult to implement in worldwide organizations

- Training, network inaccessible 12AM - 5AM

Multi-factor Authentication: 4.6

Prove who you are

- Different methods
- Memorized Passwords
- Mobile app
- GPS location

Factors:

Something you know

Something you have

Something you are

Something you are

Something you know:

Password: secret word / phrase

PIN: 4 digits

Pattern: only if you know format

Something you have:

SmartCard

USB security key

Hardware / Software token

Cell Phone

Something You are:

Biometric authenticator

Usually stores a mathematical representation of you

Difficult to change

Used in very specific situations

Something You are:

Location based Factor

IP address: Not perfect, but okay

Mobile Device Location Services

- GPS Coordinates

- Must have service

Password Security: 4.6

Password Complexity + length

Increase Password entropy

- No single words, obvious patterns
- Mix upper + lowercase, number, + special char

Stronger passwords are ≥ 8 chars

Phrase or set of words

Password age + expiration

Password age: Since last modified

Expiration:

Warn for period of time

- 30, 60, 90 days

Critical systems may often change

Password managers:

Use different passwords for each account

Store your passwords in single database

- Encrypted, Protected

Built into many OS

Enterprise password managers

Password authentication:

Many breaches due to Poor Passwords Comp

Authenticate without a Password

Facial recognition keys

Used in conjunction many times

Just-in Time Permissions:

Grant Administrative Access for Period of time

IT team assign Administrator / root / etc

Request Permission from a Central Clearing house

Password vaulting:

- Primary Credentials are stored in a Password vault

- Contains who gets Access to Credentials

Scripting and Automation: 4.7

Automate + Orchestrate

- You don't have to be there
- Solve Problems in your sleep

Need For Speed

- Extremely Fast, and Precise

Automate Mundane tasks

Automation Benefits:

Save time

Enforce Policies

- Auto install patches

Standard Infrastructure Configuration

- Builds default config configurations
- Add firewall rules

Standardized & easy

Automation Benefits:

Secure scaling

- Orchestrate cloud resources
- Quickly scale up/down

Employee Retention

'Leave the workload'

Automation Benefits:

Reaction time

- Much faster than you

Runs 24/7, Multiple work items

Cases for Automation:

User + Resource Provisioning

- On boarding / offboarding

Guard Rails!!

- Set of automated boundaries
- Limits behavior + responses
- Reduce errors

Cases for automation:

Security Groups

- Assign or remove group access
- Conduct audits

Ticket Creation

- Automatically identify issues

Escalation: Correct issues before involving human

- Escalate if needs

Cases for automation:

Controlling Services & Access

Continuous Integration & Deploy

Integration & Application Prog. interfaces (APIs)

Scripting Considerations:

Complexity, extensible testing

Cost: takes T+M to create

Single Point of failure for all devices

Technical Debt: Patching problems may push issues down the road

Organizing Subprocesses

- Plan for changes & updates

Incident Responses: 4.8

User downloads email with malware

DDos

Confidential information is stolen

User installs Peer-to-Peer Software and allows access to internal server

NIST SP800-61

National Institute of Standards & Technology

The Incident Response lifecycle:

Preparation, Analysis, Detection, Containment, Eradication, and Recovery

Post incident

Preparing for an incident:

Communication Methods

Incident handling hardware & software

· Logs, logs, forensic software

Incident Analysis teams

· Documentation, Network diagrams

Incident Mitigation techniques

POI: Cries for incident handling

The Challenge of detection:

Many different detection sensors

A large amount of "Volume"

- How do you identify the legitimate threat?

Incidents are complex, need knowledge

Analysis:

An incident might occur in the future

Web Server Log: Vulnerability Scan in use

Exploit Announcements

Direct Threats

Analysis:

An attack is underway

- Buffer overflow attempts

- Anti-virus software identifies malware

- Host-based monitor detects a config change

- Network traffic increase

Isolation and Containment:

Sandbox

- Testing malware on isolated environment

Isolation can be problematic

- Malware can identify this isolation

Recovery after an incident:

Get things back to normal

Eradicate the bug

Recover the system

- Replace corrupted files

Lessons Learned:

Learn + Improve

Post-Incident Meeting

Don't wait too long

"What happened exactly?"

- Timestamp of events

How well did our planning work

What went well & did differ

What did we miss

Training before incident

Needs to occur prior to an incident

Be ready when an incident is identified

Can be very expensive

Well worth it

Incident Planning: 8.8

Exercising:

Test Yourself Prior to actual event

Use Well defined rules of Engagement

Very Specific Scenarios

Evaluate Response

Tabletop Exercise:

Performing a smaller scale logistical security breach

- Discussed in hypotheticals

- Discussed around table

- Takes a couple hours

Get Key Players in

Simulation:

Send out Phishing emails

Call the help desk to Social Engineer

- Train the people who fail Marc

Root Cause Analysis:

Determine the Ultimate Cause of the event

Create a Set of Conclusions Regarding the incident

· Backed by facts

Don't get tunnel vision. No single root cause

Mistakes occur, user error

Threat Hunting:

Constant game of cat and mouse

Reach Vulnerability Prior to attack

Use technology to monitor & automate

Digital Forensics: 4.8

Collect & Protect information leading to an intrusion

- Many different sources & protection mechanisms

RFC 3277 Guidelines

Standards for digital forensics process

Must be detail oriented

- Take notes

Legal Hold:

Legal technique to preserve relevant information

Hold Notification: Customers are informed to preserve data

- Setaside repository for electronically stored information (ESI)

- Many different sources & types

- Unique workflow & retention reviews

Organizing Preservation.

Chain of Custody:

Control Evidence: Maintain Integrity

Everyone who touches the evidence

- User hashes & digital signatures
- Avoid tampering

Label and Catalogue everything.

- Digitally tag all items for ongoing documentation

Acquisition:

Obtain the data

- Disk, RAM, Firmware, OS Files, etc.

Some of the data may not be in a single system

For VMs, get a Snapshot

Look for left-behind digital items

Reporting:

Document the Findings

Summary information

Describe Step-by-Step acquisition

- May be used for legal Proceedings

The Findings/Analysis

Preservation:

Handling evidence

- Isolate & Protect the data

Work from copies

Manage the data collection from mobile devices

Live collection is an important skill

- Data may be encrypted, or difficult to collect after powering down

E-discovery:

Electronic Discovery

- Collect, Process, Review, Integrate

Gathers data for legal / forensic purposes

- Determine that data was deleted / Recover

Log Data: 4.9

Security Log Files:

Detailed Security related information

- Blocked / Allowed traffic flows

- Exploit attempts

- Blocked URL categories

- DNS sinkhole traffic

Critical Security information

Firewall Logs:

Traffic that flows

- Source / Destination IPs, Port numbers, direction

NGFWs

- Applications in use, URL filtering, suspicious data

Application Logs:

Specific to application

Windows: Event Viewer / App logs

Linux / MacOS: /var/log

Endpoint Logs:

Attackers gain access to endpoints

- Phones, Laptops, tablets, desktops, Servers, etc.

There's a lot of data on the endpoint

- Login events, Policy changes, System errors, Processes

Everything runs up to the SIEM

Use with correlation of security events

- Correlate IPs with endpoint security

OS-Specific Security Logs:

OS Security Events

- Monitoring C&Ms
- Blue Force, i.e. Changes
- Authentication details

Find Problems before they happen

- BF Attacks

Malicious filtering

IPS/IDS Logs

Usually integrated into NIDS

Logs contain information about Potential Vulnerabilities

- Known OS Vulnerabilities, Generic Security errors

Network Logs:

- Switches, Routers, Access Points, VPN Concentrators
- Other infrastructure devices

Network Changes

- Routing updates
- Authentication Issues
- Network Security issues

Metadata:

Data that describes other data sources

- Email: Header details, Sending Servers, destination address

Mobile: Time or Date, GPS location

Web: OS, browser type, IP address

Files: Name, Address, Phone Number, etc

- Email Header

Vulnerability Scans:

Lack of Security Controls

- No firewall
- No anti-virus
- No anti-spyware

Misconfigurations

- Open Ssh
- Guest Access enabled

Real Vulnerabilities

- External New org

Automated Reports:

Most SIEMs create automated reports

May be costly OR complex to create

Requires human intervention

Can be rather intense to create

Dashboards:

Real time Status information

Add/Remove information

Shows the highlights (or not)

Packet captures:

Solve complex application issues

- Get the details

Gathers packets on the network

- OP in the net

View detailed traffic information

- Port, Protocol, Destination / Source IP